

PROJECT 2 – WEEK 4

FINAL PENETRATION TESTING REPORT AND REMEDIATION ANALYSIS

Introduction

Penetration testing is a systematic process used to identify, analyze, and evaluate security vulnerabilities within web applications. The purpose of this project was to assess the security posture of OWASP Juice Shop by performing reconnaissance, traffic analysis, API enumeration, security misconfiguration testing, and access control assessments using industry-standard tools.

Throughout the project, multiple testing phases were conducted to understand application behavior, identify weaknesses, and document findings. The final week focused on consolidating all observations, preparing proof-of-concept documentation, and providing remediation recommendations.

Objectives

The primary objectives of Week 4 were:

- To summarize all findings identified during previous phases.
 - To validate discovered vulnerabilities.
 - To create professional Proof-of-Concept (PoC) documentation.
 - To assess the security impact of identified issues.
 - To recommend remediation strategies.
 - To prepare a comprehensive penetration testing report.
 - To document testing evidence through screenshots and logs.
-

Tools Used

Tool	Purpose
Kali Linux	Penetration Testing Platform
OWASP Juice Shop	Vulnerable Target Application
Docker	Container Deployment
Burp Suite Community Edition	Traffic Analysis and Request Manipulation
Firefox Browser	Web Application Access
Nmap	Service Discovery
cURL	HTTP Analysis and API Enumeration
Gobuster	Directory Enumeration

Final Environment Verification

Commands Used

```
"docker ps"
"nmap -sV 127.0.0.1"
```

Findings

The OWASP Juice Shop application was verified to be operational throughout the assessment period. Nmap identified active services and confirmed application availability.

Figures

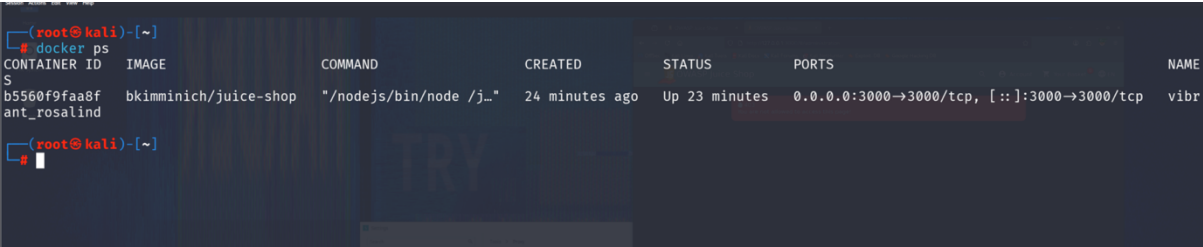


Figure 24: OWASP Juice Shop Container Running Successfully

```

(root@kali) ~
$ curl http://127.0.0.1:3000/api/Products
{"status":"success","data":[{"id":1,"name":"Apple Juice (1000ml)","description":"The all-time classic.","price":1.99,"deluxePrice":0.99,"image":"apple_juice.jpg","createdAt":"2026-06-08T11:39:29.783Z","updatedAt":"2026-06-08T11:39:29.783Z","deletedAt":null,{"id":2,"name":"Orange Juice (1000ml)","description":"Made from oranges hand-picked by Uncle Dittmeyer.","price":2.99,"deluxePrice":2.49,"image":"orange_juice.jpg","createdAt":"2026-06-08T11:39:29.783Z","updatedAt":"2026-06-08T11:39:29.783Z","deletedAt":null,{"id":3,"name":"Eggfruit Juice (500ml)","description":"Now with even more exotic flavour.","price":8.99,"deluxePrice":8.99,"image":"eggfruit_juice.jpg","createdAt":"2026-06-08T11:39:29.783Z","updatedAt":"2026-06-08T11:39:29.783Z","deletedAt":null,{"id":4,"name":"Raspberry Juice (1000ml)","description":"Made from blended Raspberry Pi, water and sugar.","price":4.99,"deluxePrice":4.99,"image":"raspberry_juice.jpg","createdAt":"2026-06-08T11:39:29.783Z","updatedAt":"2026-06-08T11:39:29.783Z","deletedAt":null,{"id":5,"name":"Lemon Juice (500ml)","description":"Sour but full of vitamins.","price":2.99,"deluxePrice":1.99,"image":"lemon_juice.jpg","createdAt":"2026-06-08T11:39:29.784Z","updatedAt":"2026-06-08T11:39:29.784Z","deletedAt":null,{"id":6,"name":"Banana Juice (1000ml)","description":"Monkeys love it the most.","price":1.99,"deluxePrice":1.99,"image":"banana_juice.jpg","createdAt":"2026-06-08T11:39:29.784Z","updatedAt":"2026-06-08T11:39:29.784Z","deletedAt":null,{"id":7,"name":"OWASP Juice Shop T-Shirt","description":"Real fans wear it 24/7!","price":22.49,"deluxePrice":22.49,"image":"fan_shirt.jpg","createdAt":"2026-06-08T11:39:29.784Z","updatedAt":"2026-06-08T11:39:29.784Z","deletedAt":null,{"id":8,"name":"OWASP Juice Shop CTF Girlie-Shirt","description":"For serious Capture-the-Flag heroines only!","price":22.49,"deluxePrice":22.49,"image":"fan_girlie.jpg","createdAt":"2026-06-08T11:39:29.784Z","updatedAt":"2026-06-08T11:39:29.784Z","deletedAt":null,{"id":9,"name":"OWASP SSL Advanced Forensic Tool (O-Saft)","description":"O-Saft is an easy to use tool to show information about SSL certificate and tests the SSL connection according given list of ciphers and various SSL configurations. <a href='\"https://www.owasp.org/index.php/O-Saft\"' target='\"_blank\"'>More ...</a>","price":0.01,"deluxePrice":0.01,"image":"orange_juice.jpg","createdAt":"2026-06-08T11:39:29.784Z","updatedAt":"2026-06-08T11:39:29.784Z","deletedAt":null,{"id":13,"name":"OWASP Juice Shop Iron-Ons (16pcs)","description":"Upgrade your clothes with washer safe <a href='\"https://www.stickeryou.com/products/owasp-juice-shop/794\"' target='\"_blank\"'>iron-ons</a> of the OWASP Juice Shop or CTF Extension logo!","price":14.99,"deluxePrice":14.99,"image":"iron-on.jpg","createdAt":"2026-06-08T11:39:29.785Z","updatedAt":"2026-06-08T11:39:29.785Z","deletedAt":null,{"id":14,"name":"OWASP Juice Shop Magnets (16pcs)","description":"Your fridge will be even cooler with these OWASP Juice Shop or CTF Extension logo <a href='\"https://www.stickeryou.com/products/owasp-juice-shop/794\"' target='\"_blank\"'>magnets</a>","price":15.99,"deluxePrice":15.99,"image":"magnets.jpg","createdAt":"2026-06-08T11:39:29.785Z","updatedAt":"2026-06-08T11:39:29.785Z","deletedAt":null,{"id":15,"name":"OWASP Juice Shop Sticker Page","description":"Massive decoration opportunities with these OWASP Juice Shop or CTF Extension <a href='\"https://www.stickeryou.com/products/owasp-juice-shop/794\"' target='\"_blank\"'>sticker pages</a>! Each page has 16 stickers on it.","price":9.99,"deluxePrice":9.99,"image":"sticker_page.jpg","createdAt":"2026-06-08T11:39:29.785Z","updatedAt":"2026-06-08T11:39:29.785Z","deletedAt":null,{"id":16,"name":"OWASP Juice Shop Sticker Single","description":"Super high-quality vinyl <a href='\"https://www.stickeryou.com/products/owasp-juice-shop/794\"' target='\"_blank\"'>sticker single</a> with the OWASP Juice Shop or CTF Extension logo! The ultimate laptop decal!","price":4.99,"deluxePrice":4.99,"image":"sticker_single.jpg","createdAt":"2026-06-08T11:39:29.785Z","updatedAt":"2026-06-08T11:39:29.785Z","deletedAt":null,{"id":17,"name":"OWASP Juice Shop Temporary Tattoos (16pcs)","description":"Get one of these <a href='\"https://www.stickeryou.com/products/owasp-juice-shop/794\"' target='\"_blank\"'>temporary tattoos</a> to proudly wear the OWASP Juice Shop or CTF Extension logo on your skin! If you tweet a photo of yourself with the tattoo, you get a couple of our stickers for free! Please mention <a href='\"https://twitter.com/owasp_juiceshop\"' target='\"_blank\"'><code>@owasp_juiceshop</code></a> in your tweet!","price":14.99,"deluxePrice":14.99,"image":"tattoo.jpg","createdAt":"2026-06-08T11:39:29.785Z","updatedAt":"2026-06-08T11:39:29.785Z","deletedAt":null,{"id":18,"name":"OWASP Juice Shop Mug","description":"Black mug with regular logo on one side and CTF logo on the other! Your colleagues will envy you!","price":21.99,"deluxePrice":21.99,"image":"fan_mug.jpg","createdAt":"2026-06-08T11:39:29.785Z","updatedAt":"2026-06-08T11:39:29.785Z","deletedAt":null,{"id":19,"name":"OWASP Juice Shop Hoodie","description":"Mr. Robot-style apparel. But in black. And with logo.","price":49.99,"deluxePrice":49.99,"image":"fan_hoodie.jpg","createdAt":"2026-06-08T11:39:29.785Z","updatedAt":"2026-06-08T11:39:29.785Z","deletedAt":null,{"id":20,"name":"OWASP Juice Shop CTF Velcro Patch","description":"4x3.5\" embroidered patch with velcro backside. The ultimate decal for every tactical bag or backpack!","price":2.92,"deluxePrice":2.92,"image":"velcro-patch.jpg","createdAt":"2026-06-08T11:39:29.785Z","updatedAt":"2026-06-08T11:39:29.785Z","deletedAt":null,{"id":21,"name":"Woodruff Syrup \"Forest Master X-Treme\"","description":"Harvested and manufactured in the Black Forest, Germany. Can cause hyperactive behavior in children. Can cause permanent green tongue when consumed undiluted.","price":16.99,"deluxePrice":16.99,"image":"woodruff_syrup.jpg","createdAt":"2026-06-08T11:39:29.785Z","updatedAt":"2026-06-08T11:39:29.785Z","deletedAt":null,{"id":22,"name":"Green Smoothie","description":"Looks poisonous but is actually very good for your health! Made from green cabbage, spinach, kiwi and grass.","price":1.99,"deluxePrice":1.99,"image":"green_smoothie.jpg","createdAt":"2026-06-08T11:39:29.785Z","updatedAt":"2026-06-08T11:39:29.785Z","deletedAt":null,{"id":23,"name":"Quince Juice (1000ml)","description":"Juice of the <em>Cydonia oblonga</em> fruit. Not exactly sweet but rich in Vitamin C.","price":4.99,"deluxePrice":4.99,"image":"quince.jpg","createdAt":"2026-06-08T11:39:29.785Z","updatedAt":"2026-06-08T11:39:29.785Z","deletedAt":null,{"id":24,"name":"Apple Pomace","description":"Finest pressings of apples. Allergy disclaimer: Might contain traces of worms. Can be <a href='\"#recycle\"'>sent back to us</a> for recycling.","price":0.89,"deluxePrice":0.89,"image":"apple_pressings.jpg","createdAt":"2026-06-08T11:39:29.785Z","updatedAt":"2026-06-08T11:39:29.785Z","deletedAt":null,{"id":25,"name":"Fruit Press","description":"Fruits go in. Juice comes out. Pomace you can send back to us for recycling purposes.","price":89.99,"deluxePrice":89.99,"image":"fruit_press.jpg","createdAt":"2026-06-08T11:39:29.785Z","updatedAt":"2026-06-08T11:39:29.785Z","deletedAt":null,{"id":26,"name":"OWASP Juice Shop Logo (3D-printed)","description":"This rare item was designed and handcrafted in Sweden. This is why it is so incredibly expensive despite its complete lack of purpose.","price":99.99,"deluxePrice":99.99,"image":"3d_keychain.jpg","createdAt":"2026-06-08T11:39:29.785Z","updatedAt":"2026-06-08T11:39:29.785Z","deletedAt":null,{"id":29,"name":"Strawberry Juice (500ml)","description":"Sweet & tasty!","price":3.99,"deluxePrice":3.99,"image":"strawberry_juice.jpeg","createdAt":"2026-06-08T11:39:29.786Z","updatedAt":"2026-06-08T11:39:29.786Z","deletedAt":null,{"id":30,"name":"Carrot Juice (1000ml)","description":"As the old German saying goes: \"Carrots are good for the eyes. Or has anyone ever seen a rabbit with glasses?\"","price":2.99,"deluxePrice":2.99,"image":"carrot_juice.jpg","createdAt":"2026-06-08T11:39:29.786Z","updatedAt":"2026-06-08T11:39:29.786Z","deletedAt":null}]}]}

```

Figure 25: Final Service Enumeration Using Nmap

Testing Methodology

The assessment followed the following phases:

Phase 1: Reconnaissance

Activities:

- Service Enumeration
- Port Scanning
- Application Discovery

Tools:

```
nmap -sV 127.0.0.1"
```

Phase 2: Traffic Analysis

Activities:

- HTTP Request Analysis
- HTTP Response Inspection
- API Enumeration

Tools:

```
"curl http://127.0.0.1:3000/api/Products"  
"curl http://127.0.0.1:3000/api/Challenges"
```

Phase 3: Security Assessment

Activities:

- Security Misconfiguration Testing
- Broken Access Control Testing
- Authentication Analysis
- Input Validation Testing

Tools:

- Burp Suite
 - Browser Testing
 - cURL
 - Gobuster
-

Findings and Vulnerability Assessment

Finding 1: Security Misconfiguration

Description

The application exposed administrative configuration information through publicly accessible endpoints.

Evidence

```
"curl http://127.0.0.1:3000/rest/admin/application-configuration"
```

Impact

- Information Disclosure
- Increased Attack Surface
- Reconnaissance Facilitation

Risk Level

Medium

Remediation

- Restrict Administrative Endpoints
 - Implement Authentication Controls
 - Disable Unnecessary Information Disclosure
-

Finding 2: Information Disclosure Through APIs

Description

Several APIs exposed application metadata and internal information.

Evidence

```
"curl http://127.0.0.1:3000/api/Products"  
"curl http://127.0.0.1:3000/api/Challenges"
```

Impact

- Exposure of Application Structure
- Improved Attacker Reconnaissance

Risk Level

Medium

Remediation

- Limit Information Exposure
 - Apply Proper Authorization Checks
-

Finding 3: Broken Access Control Assessment

Description

Restricted resources were tested to determine whether unauthorized access was possible.

Evidence

```
"#/administration"  
"#/privacy-security"  
"#/accounting"
```

Impact

Potential unauthorized access to administrative functionality.

Risk Level

Medium

Remediation

- Enforce Server-Side Authorization
 - Implement Role-Based Access Control
 - Deny Access by Default
-

Finding 4: Input Validation Testing

Description

Basic XSS payloads were tested against application input fields.

Payload

```
"<script>alert(1)</script>"
```

Result

The payload was not executed, indicating the presence of input filtering or sanitization mechanisms.

Risk Level

Low

Remediation

- Continue Input Validation
- Use Context-Aware Output Encoding

Vulnerability Summary

Vulnerability	Risk	Status
Security Misconfiguration	Medium	Identified
Information Disclosure	Medium	Identified
API Enumeration	Low	Identified
Broken Access Control	Medium	Tested
Authentication Analysis	Medium	Tested
Input Validation Testing	Low	Tested

Proof-of-Concept (PoC)

Vulnerability Name

Security Misconfiguration

Description

Administrative configuration information was accessible through a publicly exposed endpoint.

Steps to Reproduce

1. Open Burp Suite.
2. Browse OWASP Juice Shop.
3. Capture request:

"GET /rest/admin/application-configuration"

4. Analyze response.
5. Observe exposed configuration information.

Impact

Attackers may gain insight into application internals and use the information to facilitate future attacks.

Remediation

Restrict access to administrative APIs and implement authentication controls.

Issues Encountered and Resolutions

Issue 1: Burp Suite Traffic Capture Failure

Cause:

Incorrect browser proxy configuration.

Solution:

Configured Firefox to use Burp Proxy.

Result:

Traffic successfully captured.

Issue 2: Docker Container Accessibility Issues

Cause:

Container configuration problems.

Solution:

Restarted Docker container and verified service availability.

Result:

Application became accessible.

Issue 3: Empty Burp Site Map

Cause:

Community Edition limitations.

Solution:

Used HTTP History and Repeater for analysis.

Result:

Successfully analyzed application traffic.

Outcome

The penetration testing assessment of OWASP Juice Shop was successfully completed.

Achievements

- Reconnaissance completed.
 - Traffic analysis performed.
 - API endpoints identified.
 - Authentication workflow analyzed.
 - Security Misconfiguration tested.
 - Broken Access Control assessed.
 - Input validation testing performed.
 - Proof-of-Concept documentation prepared.
 - Remediation recommendations provided.
-

Conclusion

The Web Application Penetration Testing project successfully demonstrated the practical use of industry-standard tools such as Burp Suite, Nmap, Docker, Gobuster, and cURL. Multiple security assessment techniques were applied to OWASP Juice Shop to understand application behavior, identify potential weaknesses, and document security findings. The project provided valuable hands-on experience in reconnaissance, traffic analysis, vulnerability assessment, and reporting, thereby strengthening practical cybersecurity skills and knowledge.
